

Communication Best Practices for Cyber Incidents

Modes of Learning

For this module, the following modes of learning will be used:

- Interactive Module
- Online Quizzes
- Written Reports

Introduction

From political entities and academic institutions to health care providers and utility distributors, no industry is immune to the reputational damage that cybercrime can inflict. While the startling number of cyberattacks ensures that cybersecurity is important, organizations often prioritize the financial, legal and technical ramifications of a breach over and above reputational damage.

Many organizations continue to overlook planning a communications strategy, despite estimates that organizations will spend \$1 trillion USD cumulatively over the next five years to defend against cybercrime, with cybersecurity products and services.

In many instances, breaches are communicated by an outside party such as a bank, credit card network, law enforcement agency or the media, as opposed to the organization experiencing the breach. This dynamic often leaves organizations scrambling to determine what to say, how to say it, and which experts to bring in—delaying an effective response.

The usual strategy during crisis is to communicate quickly, regularly and in all channels where the organization's audience is watching. However, communicating after a cyber incident demands a different approach and has its unique set of best practices and guidelines.

As you begin this module, please refer to the timeline and make note of any assessments or important dates. If you have any questions, ask your instructor.

Learning Outcomes

Upon completion of this module, you will be able to:

1. Describe the necessary actions to take before a cyber incident occurs, to mitigate its negative effects.
2. Describe an appropriate communications strategy to employ during a cyber incident.
3. Describe a suitable strategy for after a cyber incident, to assess response plans and their application, and to repair damaged reputation.

Key Terms & Concepts

Listed below are some important key terms and concepts within this module.

- Communication Plan
- Potential Third-Party Organizations
- Response Tree
- Media Relations Strategy

Phase One: Before an Attack

“Be ready to make changes on the battlefield—we all know that no plan survives contact with the enemy.” This quote is attributed to Helmuth von Moltke, a 19th century Prussian field marshal.

Attacks—whether on the battlefield or on an organization’s cybersecurity—do not follow a predictable and prescribed formula. Hence, having a high-level guiding strategy that can be applied in these situations is critical to mitigating damage and restoring business. While each phase within a crisis cycle is important, skipping the planning phase leaves any organization at a critical disadvantage.

There are four distinct pieces that an organization must consider when preparing for a potential cyber incident: People, Plan, Prepare and Practice.

[Click to Watch: How FinTech Companies can Prepare for a Large-Scale Cyber Attack](#)

Denial of Service (Availability)

- Access of customers
- Availability of data, systems, and services
- DDOS network attacks, ransom-ware data locking attacks

Data Theft and Exposure (Confidentiality)

- ID Theft and privacy
- Data breach and transaction data
- Database hacks, skimming, lost storage, keylogging

Monitor and Manipulate (Integrity)

- Internal-access surveillance for advantage
- Tamper/Manipulation
- Long-term data gathering campaign

Own and Obliterate (Confidentiality, Integrity, and Availability)

- Administrative ownership and control
- Capability of unrecoverable obliteration
- Strategic attack, undermining of org capability

Phase One: Before an Attack

Cybersecurity Incident Checklist: Before an Incident

- Create a prioritized list of information assets critical to the functioning of your organization.

- Identify the stakeholders responsible for each critical asset.
- Create an Incident Response Team (including individuals from legal, corporate communications and HR) that will be responsible for all incidents.
- Ensure proper monitoring and tracking technologies are in place (such as firewalls, IPS and anti-virus software) to protect your organization's information assets.
- Provide media training to the proper individual(s).
- Provide a company-wide process for employees, contractors and third parties to report suspicious or suspected breach activities.
- Provide company-wide training on breach awareness, employee responsibility and reporting processes.

Assemble the Right People

A communications plan for cyber incidents should never be developed in a silo. Cyber incidents are not strictly legal, IT or communications problems: they are business problems that require a holistic solution from a multi-disciplinary team.

A cyber incident communications plan needs input and influence from people in several branches of an organization: senior leadership, IT, operations, communications, legal/risk, human resources, and managers responsible for stakeholder audiences such as investors, customers, and business operations. Developing a plan without a holistic view of the operation will leave potentially dangerous gaps when executing the plan.

Plan and Prepare

- Senior management commitment
- IRT formed
- Test procedures
- Security awareness
- Apply safeguards

Detect and Report

- Monitor security systems and feeds
- Detect cybersecurity incidents

Assess and Decide

- Is it really an incident?
- Triage and prioritize

Respond

- Contain, eradicate, recover from and forensically analyze the incident

Post-Incident Activity

- Lessons learned
- Evidence retention
- Continuous improvement

Relying on internal experts is necessary, but it is equally important to bring in external subject matter experts. A crisis, whether planning for one or dealing with one, is not the place for novice communicators

to learn on the job by handling it alone. Communications consultants who have navigated multiple cyber incidents, and external legal counsel who specialize in cyber breaches, will bring a wealth of knowledge and experience to the team. They will ensure a solid plan is in place and will save much needed time by bringing best practices to the table.

External advisors and the internal team need to be acquainted with one another before a crisis. Understanding the role each group plays, and how everyone will work together during a crisis, will help the team navigate the event more smoothly and efficiently.

Once the team is assembled, determine a chain of approvals and authorities with clear lines of responsibility. Clarifying this process well in advance of an incident will save precious time when it comes to sharing information publicly during a crisis.

2. Develop a Plan

A communications plan needs to be developed by communications experts. However, IT's input is also needed to form a comprehensive cyber response plan. Organizations often develop their plans in siloes, without insight into other departments' plans, resulting in a series of one-sided strategies that do not necessarily work in harmony or address all risks.

Identifying risk is the first step to developing a plan. Identifying unique organization- and industry-specific risk factors and assessing their impact will guide the preparation process. For instance, a retailer's risks would likely tend to focus on credit card and customer information breaches, whereas a utility provider would need to consider how to respond to a breach during an interruption of vital services to its customers.

In addition to preparing for breach scenarios, every organization should consider the consequences of a breach of any sensitive or private information, e.g. proprietary marketing data, employees' personal or health records.

The team should consider every angle and potential scenario, mapping a response for each scenario and incorporating enough flexibility to account for unforeseen details. Assessing potential breach scenarios and forging communication responses in advance will allow the team to act calmly and thoughtfully during an otherwise stressful situation.

During this stage it is crucial to have legal counsel on the team, to provide expertise on laws and regulations that will dictate how, when and to whom communications must occur.

Next, consider timing. Communications strategies and tactics should align with both IT's and forensics' timelines, as well as any timelines mandated by law, e.g. notification requirements.

During the planning phase, it is also important to determine who in the organization will be the 'face' of a crisis, and to provide this person media training. This spokesperson must be comfortable in front of a camera and able to answer difficult questions well. Having a trained, confident spokesperson in advance will prevent miscommunication in a difficult time.

3. Prepare All Assets

The communications playbook should include information, resources and starter materials to expedite an articulate response. Incorporate a portfolio of template materials that can be prepared in advance, including the following:

- Messaging guidelines
- Holding statements
- Press releases
- Q&A/FAQ documents
- Internal briefing materials

While the templates should not contain specific details—the who, what, when, where, why, and how of the incident—they establish a framework and identify the essentials to include for each communication.

Drafting these starter documents allows for advance brokering between the management, communications and legal teams, to determine appropriate tone and language for communicating with internal and external audiences. In addition, the organization should consider how and where to best present information online, which might include developing a “dark website” that can be populated in advance and pushed live at the appropriate time.

The primary communications goal should be to get the right information to the audience that needs it most. Monitoring and analytics tools can help the organization see beyond an established baseline of chatter, to determine who is involved in the conversation and what information is shared.

Social media can be an asset or a distraction in pursuit of communications goals. The platform should be used to demonstrate accountability and to steer audiences to the best resources for current information, such as a call centre or dedicated website section. Information shared on social media should be simple and short.

For social media, a response tree is an essential resource for anyone posting content on behalf of the organization. A response tree is a document that helps separate trolls from customers, influencers, media and government officials. It provides directive as to how each of these groups should be handled when comments are made on the client’s social accounts. Messages can be pre-approved and escalation protocol can be established with input and approval from legal, before an incident occurs.

Prepare the media spokesperson with questions from every angle of the potential scenarios, and ensure that legal counsel is on hand to help frame answers that could have legal implications. That said, there are generally too many unknown factors and/or pieces of confidential information that should not be discussed with the media in an interview, so press conferences or open interviews are not recommended as part of a breach response. Having said that, it is prudent to have a trained and ready spokesperson on hand, should the need for one arise.

During a cyber incident, answers do not unfold quickly, as forensics investigators need time, leaving little information for an internal spokesperson to share. This lack of information can be interpreted by the public as an effort to hide the facts. To mitigate potential reputational damage caused by the breach and subsequent trickle of information, finding others who can credibly come to the organization’s defence, and speak to its record (or the industry’s record), is critical. Potential third-party organizations such as

trade associations can be identified in advance and prepared to speak on behalf of the organization and its history.

4. Practice Your Execution

Most organizations deem their cybersecurity communications plan to be sufficient—until a breach occurs. Often, organizations skip the crucial step of pressure-testing their plan with a cyber incident response drill.

Practiced in a controlled setting, a response drill serves multiple purposes. It allows the response team member to practice working together, and to determine how their areas of expertise and personalities will complement and clash during a crisis. A drill also identifies flaws and gaps in the process: what looks right on paper does not always work in practice. A response drill is a safer and less costly way of identifying and smoothing logistical kinks than doing so in the midst of a real breach.

Assembling the response team to stress-test their plan—through a detailed crisis simulation or even a simple tabletop drill—often reveals that every member has a slightly different impression of how things would and should work. Additionally, personalities often change during stressful events, and people behave differently in a crisis: traditionally calm and level-headed thinkers can panic under heavy stress. The time to recognize and account for these changes is during a simulation scenario, not a legitimate crisis.

Ideally, these drills should occur at least once a year or whenever there is an organizational change concerning leadership, products, services, division or any other factor that could affect an organization's risk profile. Drills should also occur if relevant industry regulations change.

Following a drill, be sure to review and refine the plan based on lessons learned during the drill, so that the plan is as up to date as possible.

Phase Two: During an Attack

As practiced and prepared as an organization might be, cyberattacks are still unpredictable and unexpected, which is why preparing a plan is so critical. The plan must be used as a roadmap to guide responses and reinforce timing.

Once a breach occurs, it is time to use the playbook to customize a deliberate and tightly sequenced release of information that gets the right information to the right audience, at the right time and in the right order. Communications documents' messaging should be refined, with the blanks in the templates filled with incident-specific information.

Regardless of the breach details, the tone of communications should be humble. An organization must never position itself as a victim, but it should express regret for what has occurred; it should assure the public that it is taking steps to fix the situation and to prevent future breaches. In its communications, an organization must project diligence and competence in protecting the well-being of its customers and stakeholders.

[Click to Watch: Herjavec Group Incident Responses and Remediation Services](#)



Cybersecurity Incident Checklist: During an Incident

- Record the issues and open an incident report.
- Convene the incident response team.
- Convene a teleconference with the appropriate internal stakeholders to discuss what must be done in order to restore operations.
- Convene a management teleconference with the appropriate internal stakeholders in order to provide situational awareness to executive management.
- Identify the initial cause of the incident, and activate the specialists to respond to the current issues to restore operations.
- Retain any evidence and follow a strict chain of evidence to support any needed or anticipated legal action.
- Communication to affected third parties, regulators and media (if appropriate).

During this phase, it is critical for the communications team to work with the legal team, to ensure notification obligations are met and to determine what and how to communicate. This close alliance will help protect the organization legally and reputationally, by balancing privileged information with what the public has the right to now.

Next, consider the media relations strategy. Cyber incidents pose a particular challenge with media relations, as the media's coverage can positively or negatively affect the public's perception of a breach.

The media's response will be difficult to predict because it will be influenced by circumstances other than the facts of the breach. The overall context in which the breach occurs can propel the breach into a lead story and keep it the headlines for days or even weeks:

- A slow news cycle
- Opportunistic politicians or regulators
- Proximity to other well-known breaches

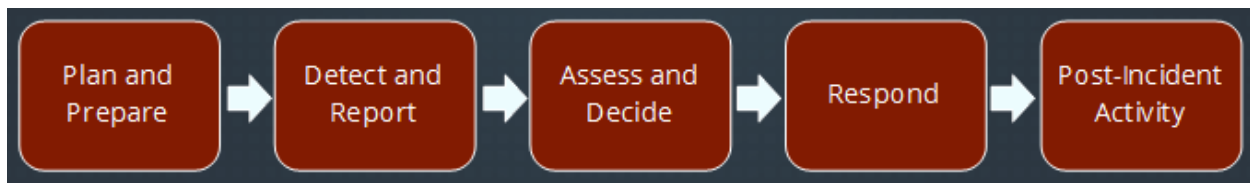
- The unusual nature of hackers or information exposed

While it is usually impossible to prevent media coverage, it is possible to predict and address the elements that can fuel a story.

Once an incident is made public, the response tree should be activated immediately, by implementing social media monitoring that compiles commentary on the breach and analyzes it for indicators of coverage and conversation trends. This includes quantitative analysis, to determine how the breach compares with other major events in the corporate narrative.

Qualitative analysis will provide insight into specific concerns stakeholders are raising online, so appropriate action can be taken and addressed in future communications. The third-party spokesperson should be deployed to face the media.

At all times during this phase, the crisis team needs to work together to adhere to the guiding strategy. Team members need to remain transparent with one another, to ensure decisions are made with the correct information and that no one acts outside of the agreed plan.



Phase Three: After the Attack

After a breach, the organization should conduct an audit of its reputation and develop a plan to repair it. Repairing the organization's reputation will entail:

- Monitoring media and social media channels, using the response tree to plan and prioritize responses.
- Rolling ongoing communications into a reputation-recovery program for the organization or affected brand. This includes repairing and maintaining stakeholder relations, and establishing that trust has not wavered.
- Launching ongoing customer security assurance and recovery communications, to assuage doubts or fears that might sever customer loyalty.
- Conduct litigation communications if required. The communications team and legal team must collaborate to complete this process.
- Communicating with industry peers to inform them of key learnings or gaps in processes. The more knowledge that can be shared across industries, the better the organization will be at handling cyber incidents.

Cybersecurity Incident Checklist: After an Incident

- Update the incident report and review exactly what happened and at what times.
- Review how well the staff and management performed during the incident.
- Determine whether or not the documented procedures were followed.
- Discuss any changes in process or technology required to mitigate future incidents.
- Determine what information was needed sooner.

- Discuss whether any steps or actions taken might have inhibited the recovery.
- Determine which additional tools or resources are needed to detect, triage, analyze and mitigate future incidents.
- Discuss what reporting requirements are needed (such as regulatory and customer).
- If possible, quantify the financial loss caused by the breach.

It will also be important to conduct an audit of the organization's reputation after a breach and develop a plan to repair it. Monitor media and social channels and continue to use the response tree to plan and prioritize what needs to be addressed. Roll ongoing communications into a reputation-recovery program for the organization or the affected brand. This includes repairing stakeholder relations, ensuring those bonds continue to be strong, and establishing that trust has not wavered. Similarly, launch ongoing customer security assurance and recovery communications to assuage any doubts or fears that may sever customer loyalty. Additionally, the communications team and legal team must work together to conduct litigation communications, if required.

Finally, communicate any key learning or gaps in processes with industry peers. The more knowledge that can be shared across not just an organization but industries, the better the organization will be at handling cyber incidents.

Module Summary

In this module you have learned:

1. Proper cyberthreat management should include appropriate communication strategies.
2. Organizations should not improvise communication strategies and should instead rely on proven cybersecurity communication experts and legal counsel.

Knowledge Check

The following questions provide an opportunity for you to see what you remember and understand so far. Answer the questions to the best of your ability.

1. **In many instances, breaches are communicated by an outside party such a bank, credit card network, law enforcement agency or the media, as opposed to internal IT department.**
 - a. True
 - b. False
2. **To control the media's narrative about a breach, an organization should release detailed information or speculation about causes.**
 - a. True
 - b. False
3. **The usual strategy during a cybersecurity crisis is to communicate quickly and in all the channels where the organization's audience is watching.**
 - a. True
 - b. False
4. **Cyber incidents are not legal, IT or communications problems. They are business problems.**
 - a. True
 - b. False

5. **There are four distinct pieces that an organization needs to consider when preparing for a potential cyber incident: People, Plan, Prepare and Practice.**
 - a. True
 - b. False
6. **Potential third-party organizations, such as trade associations, can be identified in advance to speak on behalf of an organization and its history.**
 - c. True
 - d. False
7. **Often, organizations skip the crucial step of pressure-testing their plan with a cyber incident response drill.**
 - a. True
 - b. False
8. **An organization must never position itself as a victim, but it should express regret for what has occurred; it should assure the public that it is taking steps to fix the situation and to prevent future breaches.**
 - a. True
 - b. False

Answers:

1. True
2. The answer is false because the response tree should be immediately activated by implementing social media monitoring that compiles commentary on the breach, and analyzes it for indicators of coverage and conversation trends.
3. The answer is false because communicating after a cyber incident demands a different approach and has its own unique set of best practices and guidelines.
4. True
5. True
6. True
7. True
8. True

You have completed: Best Practices for Cyber Incidents

Remember to check the timeline before you proceed to the next module to ensure you have completed any assignments as required. Check with your instructor if you have any questions.